HL-CYB-001

Lab implementation guide: stages A-L

Enterprise Zero Trust Security Architecture

Document version 1ae176384d19

PLANNED - operational controls NOT TESTED

Contents

1. How to execute a future approved stage 3

2. Stage A - Hardware and virtualization readiness 4

3. Stage B - Proxmox installation and baseline hardening 6

4. Stage C - Virtual enterprise networking and isolation 8

5. Stage D - Virtual OPNsense firewall 10

6. Stage E - Windows Server Evaluation, AD, DNS, and GPO 12

7. Stage F - Linux and Windows endpoints 14

8. Stage G - Enterprise PKI and identity security 16

9. Stage H - Least privilege and Zero Trust policies 18

10. Stage I - Lab-only Tailscale and Twingate pilots 20

11. Stage J - Security monitoring and audit logging 22

12. Stage K - Functional, negative, and security validation 24

13. Stage L - Automation, recovery, and final documentation 26

14. Task 001 stop 27

Status: PLANNED. Operational controls are NOT TESTED. This guide explains how to build and verify the isolated lab after approval. It does not authorize execution. Obtain the owner's approval for each stage; Stage A readiness is the recommended first engineering step.

The assignment defines the business requirements; its Expected Deliverables defines the eight submission filenames used by the editable lab templates. The architecture defines the zones and allowed flows. Use the glossary for terms such as bridge, certificate authority, Group Policy, and recovery objectives. Each stage below states its prerequisites, actions, expected result, checks, recovery steps, and completion criteria.

1. How to execute a future approved stage

Before work, create the next sequential draft task report. Record the approved scope/date/reference, operator, versions, private target inventory, intended changes, expected results, tests, stop conditions, and rollback. Check current vendor instructions and compatibility.

Work from a clean task branch and update the design before changing the lab. Execute only the approved stage, retain raw evidence privately, and publish reviewed synthetic summaries. Finalize the task report after verification and keep owner user acceptance testing (UAT) separate. A task needs its finalized report to be engineering-complete; finishing a stage never authorizes the next one.

All commands below are **proposed examples, not executed lab commands**. Their syntax was checked against vendor documentation for the blueprint. Before using one, confirm the approved lab target, installed version, and local help. Set variables such as `$LabDnsAddress` and `$LabCertificatePath` privately using reviewed lab-only values. Never put secrets or actual addresses in Git. Use version-matched official references, including when screen labels differ from this guide.

Stop if an asset/disk is uncertain, a protected network becomes reachable, rollback is unavailable, output exposes a secret, a check fails, or work would exceed approval. If isolation is in doubt, disconnect the lab uplink through the approved console procedure. Preserve evidence privately and record the issue. Do not connect the lab to home/production to work around a dependency.

2. Stage A - Hardware and virtualization readiness

2.1. Objective

Establish whether the available devices can host the design safely before approving any installation.

2.2. Prerequisites

Owner approval for a read-only readiness assessment, access to the supplied devices, an agreed inventory/evidence location outside Git, and confirmation of who owns each device and disk. No reboot, firmware change, software installation, or security testing is included in a read-only approval.

2.3. Required tools

Use the candidate device's existing PowerShell/CIM, firmware and storage screens, physical console, and private inventory/capacity worksheet. No inspection package is installed by a read-only assessment.

2.4. Procedures

1. Inventory the Dell, Lenovo, HP, and candidate administrator/test laptops. Check CPU, RAM, disk contents/free space, supported operating systems, network interfaces, power/cooling, and physical console access. Keep serial numbers and actual addresses private.
2. Use existing tools to inspect virtualization/second-level address translation (SLAT) support and firmware settings. Record unknowns without changing firmware. Identify an existing hypervisor, disk encryption/recovery dependency, or data that must be preserved.
3. Review the proposed capacity budget, reserve/free-space requirements, and CPU contention. Verify a backup location with adequate usable space; the supplied HP is a candidate, not a proven backup target.
4. Draw a private cable/interface map. Identify a lab-only administrator station and offline management segment. Review other adapters, Wi-Fi, VPNs, sharing, and forwarding that could bridge protected networks.
5. Propose the exact disk for a future Proxmox installation, its data-preservation plan, supported boot mode, media verification method, and recovery procedure. Identify the unresolved egress boundary and any hardware dependency.
6. Publish only a sanitized readiness summary, capacity ledger, risks, and go/no-go recommendation. Request separate approval for Stage B; do not reboot into an installer.

2.5. Proposed commands

On each approved Windows lab candidate, local read-only PowerShell; command output stays private until reviewed:

```
Get-CimInstance -ClassName Win32_ComputerSystem
Get-CimInstance -ClassName Win32_Processor
Get-NetIPConfiguration -All
```

Syntax references: Microsoft inventory and network commands. Use existing firmware/storage UI for details not covered by these commands. Do not install an inspection tool during Stage A without expanded approval.

2.6. Expected outcome

A verified asset/capacity inventory, exact disk decision proposal, feasible offline topology, known backup/console recovery path, and explicitly unresolved prerequisites.

2.7. Verification

T03: compare inventory output with physical labels/firmware and storage UI without changing settings. Reconcile supplied versus observed capacity and check that the private topology shows no protected-network connection. This is not a network probe.

2.8. Troubleshooting

If supplied and observed specifications differ, record both and recheck existing firmware/storage views; do not change settings to make the inventory fit. If disk ownership, backup capacity, or console access is uncertain, issue a no-go recommendation rather than proceed to installation.

2.9. Rollback

Read-only assessment requires no configuration rollback. Close tools, retain private records, and correct any inaccurate public summary through a reviewed commit. Any requested hardware/firmware change becomes a separate approval item.

2.10. Completion criteria

R01/R02 prerequisites are documented; hardware uncertainties and blocking decisions have owners; Stage A engineering review and owner acceptance are recorded separately. No installation is claimed.

3. Stage B - Proxmox installation and baseline hardening

3.1. Objective

Install the lab's virtualization host only after the owner approves the exact disk and recovery plan.

3.2. Prerequisites

Accepted Stage A; explicit Stage B approval covering exact host/disk and destructive installation; verified backups and recovery media; physical console; supported hardware; official media and matching vendor-published checksum/signature; private administrator credentials and MFA recovery plan. Offline media/update transfer must not introduce production data.

3.3. Required tools

Use verified official installation media and its integrity-check method, the physical console, a supported browser on the isolated administrator station, a private credential/recovery store, and verified preinstallation backups.

3.4. Procedures

1. Recheck the approved disk's identity immediately before installation to prevent data loss. Disconnect unrelated disks where feasible and authorized. Stop if its labels, capacity, or contents differ from the approved record.
2. Boot verified Proxmox media from console. Select only the approved storage and a filesystem appropriate for a single disk; do not claim redundancy or create a cluster. Configure the lab-only management interface and private DNS/time plan.
3. Connect management only to the dedicated offline administrator segment. Keep ordinary guests and home uplinks off the management bridge. Leave the physical console available while changing access policy so a mistaken rule does not lock out administration.
4. Create a named lab administrator with scoped roles. Configure supported multi-factor authentication (MFA) and a protected emergency console/recovery method. Use root only for necessary setup/recovery and keep recovery secrets private.
5. Review supported update repositories/subscription terms. Apply only approved supported updates using verified offline transfer or a separately approved isolated path; record deferred updates as risk. Never disable integrity checks or use unreviewed install scripts.
6. Apply host management restrictions for the actual Proxmox firewall backend/version. Preserve a specific administrator allow rule, deny other management sources, and verify effective policy. Do not switch firewall backends blindly.
7. Record storage/free-space quotas, backup target proposal, local logging/time baseline, and host configuration recovery instructions. Do not create enterprise guests yet.

3.5. Proposed commands

No installation or firewall command is supplied as an executable shortcut. Use the verified media installer and version-matched Proxmox documentation. Inspect installed versions and effective configuration through the supported local UI/CLI help after installation; record exact commands in that stage's reviewed change record.

3.6. Expected outcome

A recoverable single lab hypervisor with an isolated management plane, scoped administrator/MFA, supported patch status, and an accurately measured capacity ledger.

3.7. Verification

T03/T04: inspect installed version, management bindings, roles, firewall state, free storage, and local logs; independently log in using the named administrator and confirm physical console recovery. Use lab-owned mock/unprivileged contexts for denied management checks only if Stage B approval covers them.

3.8. Troubleshooting

If administration is unreachable, use the physical console to inspect the management interface and specific allow rule before restoring the saved configuration. If storage or compatibility checks fail, stop and revise the approved budget/media choice; never select a different disk or disable security checks to continue.

3.9. Rollback

Use console to restore the approved prior host/network configuration if access is lost. Reinstallation is destructive and needs approval unless explicitly covered in the Stage B rollback authorization. Restore preinstallation data from the verified backup when applicable; do not overwrite another device to recover the host.

3.10. Completion criteria

R02/R03 baseline evidence, console recovery, supported-version record, private backup location, and owner acceptance exist. No VM, directory, or remote-access implementation is implied.

4. Stage C - Virtual enterprise networking and isolation

4.1. Objective

Separate the six zones without introducing an unintended route to home or production.

4.2. Prerequisites

Accepted Stage B, explicit Stage C approval, private nonoverlapping address plan, bridge/interface map, console rollback, and approved management access. All uplinks remain disconnected unless separately approved.

4.3. Required tools

Use the installed Proxmox network UI/local help, the physical console, a private interface/cable/route map, and a saved host-network configuration. Do not use an unreviewed networking script.

4.4. Procedures

1. Confirm `vmbr0` is management only and its physical port reaches only the dedicated lab administrator segment. Check that the administrator station cannot forward via Wi-Fi/another NIC.
2. Create internal bridges `vmbr10-vmbr50` for Identity, Endpoints, Services, Monitoring, and Remote access. Give them no physical ports and no hypervisor address. Publish bridge names/roles only; actual addresses remain private.
3. Record each zone's gateway and planned firewall virtual NIC mapping. Prevent the host from routing/forwarding between zones so traffic cannot bypass the firewall. The offline root CA must have no network connection.
4. Review IPv6 forwarding, RA/DHCPv6, overlay interfaces, host NAT/bridging, and any inherited defaults. Disable routed IPv6 exposure for the baseline while preserving required local OS behavior.
5. If an egress interface is proposed, create it disconnected. Verify that it is not connected to the home LAN and cannot bypass the independent protected-network boundary. Resolve DEC-03 before enabling it.
6. Save a private before/after map and host network backup. Do not start a general guest with a management or uplink adapter to test convenience connectivity.

4.5. Proposed commands

Use the version-matched Proxmox networking UI and inspect its effective bridge/port/address definitions. No host networking command is prescribed until the inspected NIC names and supported network backend are known. See Proxmox networking.

4.6. Expected outcome

Six separately defined trust zones with no physical access from workload bridges and no automatic home/production path. Routing is still absent until the approved firewall stage.

4.7. Verification

T01/T03: inspect the effective bridge membership and private cable map; compare them with the VM attachment plan and physical console view. Review routes/forwarding and IPv6 settings without probing home or production. After test guests are authorized in D/F, repeat isolation observations using lab mocks.

4.8. Troubleshooting

If a zone appears connected unexpectedly, inspect bridge physical ports, host addresses/forwarding, guest NICs, and the administrator station's other adapters. Keep the uplink disconnected while correcting the approved map; do not add a home bridge for troubleshooting.

4.9. Rollback

Restore the saved network configuration from physical console, preserving management connectivity. Remove only newly created unused bridges if explicitly covered by rollback approval; never delete an attached interface or reset the host networking wholesale.

4.10. Completion criteria

R01/R04 topology is reviewed, console rollback is viable, no actual addresses appear in Git, and owner acceptance is recorded. A configured bridge alone is not evidence of end-to-end enforcement.

5. Stage D - Virtual OPNsense firewall

5.1. Objective

Make the firewall the controlled route between zones, permitting only the declared service flows.

5.2. Prerequisites

Accepted Stage C, explicit Stage D approval, verified official OPNsense media, approved VM budget and exact vNIC-to-zone map, private rule/alias plan, console access, and disconnected WAN. Online egress remains blocked on DEC-03.

5.3. Required tools

Use verified OPNsense media, its console and management UI, the private interface/alias/flow matrix, encrypted backup storage, and only the separately approved lab mock clients for bounded checks.

5.4. Procedures

1. Create the firewall VM within the approved budget. Match its Management and internal interfaces to the bridge map, checking virtual NIC identifiers rather than guessing their order. Add the WAN interface disconnected.
2. Install from verified media at console. Assign interfaces, private addresses, and explicit gateway/routing behavior. Do not run DHCP on the management/home network or give guests a second default gateway.
3. Replace permissive installer LAN rules with the flow matrix. Permit required infrastructure dependencies narrowly. Block protected destinations before approved egress permits, then finish with logged default deny so an unlisted connection stays blocked.
4. Audit management listeners, anti-lockout rules, floating/group rules, automatic rules, NAT, existing states, IPv6, UPnP/NAT-PMP, and firewall-originated traffic. Keep a specific management allow path and console recovery before narrowing access. NAT never substitutes for a deny policy.
5. Add private aliases for protected destinations and named allowed services. Review DNS alias refresh/shared-hosting limitations. Do not publish the real alias members. Default external egress is denied, and no inbound forwarding is configured.
6. Do not blindly toggle "Block private networks" on WAN: behavior depends on the approved uplink. If a private transit source is required, document the exact exception and independent protection before changing it. No exception permits home access.
7. Enable local administrative/rule logging and save an encrypted private firewall backup outside Git. Connect an approved isolated uplink only after the owner approves its concrete topology and rollback. Otherwise leave Internet/remote-access dependencies pending.

5.5. Proposed commands

Use the supported OPNsense console/UI. No direct packet-filter disabling or blanket rule command is proposed. Review current virtual installation, rules, and interface documentation before configuration.

5.6. Expected outcome

A stateful, default-deny lab router/firewall with explicit service exceptions, protected-network exclusions, controlled management, logging, and recovery configuration.

5.7. Verification

T01/T02/T04/T05/T06: review effective rules, routes, aliases, listeners, states, and vNIC attachments. Using only approved lab mock endpoints, confirm a permitted flow and a denied flow on each relevant boundary and observe corresponding rule counters/logs. Never test protected real targets. Clear only the scoped lab test states under approval when validating a policy change.

5.8. Troubleshooting

If a required lab flow fails, check its source interface, destination alias/service, effective rule order, existing state, listener, and logs against a known working control case. If an unlisted flow succeeds, disconnect approved egress and inspect automatic/anti-lockout/NAT/IPv6 paths before restoring policy; do not disable packet filtering.

5.9. Rollback

Disconnect WAN first if isolation is uncertain. Use console to restore the last approved private configuration; do not disable the entire filter to regain access. Verify protected-network denial before reconnecting any approved uplink.

5.10. Completion criteria

R01/R03/R04 evidence passes for the implemented offline scope; any online dependency is explicitly pending. No broad LAN-allow, exposed administrator service, or unauthorized protected path remains. Owner UAT and Stage E authorization are separate.

6. Stage E - Windows Server Evaluation, AD, DNS, and GPO

6.1. Objective

Build a separate directory for synthetic users and computers, with lab DNS and Windows policy management.

6.2. Prerequisites

Accepted Stage D, explicit Stage E approval, official supported Windows Server Evaluation media/terms, approved identity VM, private DNS/address/time plan, separate lab passwords and DSRM custody, and supported identity backup/recovery design. Verify current evaluation activation/expiry requirements; no corporate tenant or product key is used.

6.3. Required tools

Use approved Windows Server media, local elevated PowerShell/Server Manager, supported AD/DNS/Group Policy management tools, private DSRM credential custody, and a supported system-state backup method.

6.4. Procedures

1. Create the DC VM on the identity bridge only, with approved CPU/RAM/disk, static private addressing, and a lab-only hostname. Patch through the approved path and record edition/build and evaluation deadlines.
2. Confirm DNS/time are consistent and no corporate suffix, resolver, trust, cloud registration, or identity sync is configured. Plan activation through approved egress if required; if no safe path exists, stop rather than attach the VM to home.
3. Install Active Directory Domain Services (AD DS) and DNS, then create the new `ad.lab.test` forest. Keep Directory Services Restore Mode (DSRM) and administrator secrets in the private store. Do not delegate DNS into production; check version compatibility before choosing a functional level.
4. Create organizational units (OUs) for users, privileged identities, servers, endpoints, and service accounts. Add three role groups, six synthetic standard users, and two separate privileged lab accounts. Delegate rights through groups so routine work does not require Domain Admin membership.
5. Configure lab forward/reverse DNS and the domain time hierarchy. Limit DNS recursion/forwarding to approved sources and upstreams. Domain members will use lab DNS only; avoid routing internal names to external resolvers.
6. Define GPO baselines for password/lockout, audit policy, host firewall, privileged logon restrictions, and endpoint administration. Pilot in a test OU, review precedence/resultant policy, and expand only after approved checks. Avoid lockout tests that threaten the only recovery administrator.
7. Establish supported system-state backup and document isolated directory recovery. A VM snapshot is not the directory backup strategy. Do not join corporate devices or enable hybrid/cloud integration.

6.5. Proposed commands

On the new approved **lab DC only**, elevated PowerShell. These commands change the server and the second can reboot it; execute only under Stage E approval after prerequisite checks:

```
Install-WindowsFeature -Name AD-Domain-Services -IncludeManagementTools
Install-ADDSForest -DomainName 'ad.lab.test' -InstallDNS
```

Allow the supported interactive secure DSRM prompt; never embed a password. Syntax: Microsoft AD deployment. Exact parameter choices/functional levels require the selected server version's help. No command is executed by Task 001.

6.6. Expected outcome

A separate synthetic directory/DNS domain, delegated role model, pilot GPO baseline, private credential recovery, and supported backup procedure.

6.7. Verification

T07/T08: check directory/DNS health and synthetic records; independently resolve a known service and inspect resultant GPO on the later approved member endpoint. Review trusted domains, DNS forwarders, cloud registration, group membership, and account counts without touching production. Record expiry/activation limitations.

6.8. Troubleshooting

If join/logon/GPO fails, inspect lab DNS records/client resolver, time, service health, and the version-specific AD dependency rules before broadening a permit. If evaluation activation lacks an approved safe path, leave it blocked and record the deadline; do not use corporate credentials, keys, or a home adapter.

6.9. Rollback

Revert only the new pilot GPO/group change using documented backups; do not demote/delete a DC casually. Recover an unusable new forest only within the approved isolated rebuild/system-state procedure. Stop and obtain further approval if recovery would affect another asset or overwrite evidence.

6.10. Completion criteria

R05 is demonstrated in the approved scope, production independence is verified by configuration review, recovery custody exists, and owner acceptance is recorded. Endpoints are not assumed joined until F.

7. Stage F - Linux and Windows endpoints

7.1. Objective

Prepare ordinary lab devices and a synthetic service so later access tests have known targets.

7.2. Prerequisites

Accepted Stage E, explicit Stage F approval, supported/licensed Windows and Linux media, endpoint VM budgets, private inventory, lab DNS/time, reviewed host firewall baseline, and clean rollback images/backups.

7.3. Required tools

Use verified endpoint media, supported Windows/Linux administration and host-firewall tools, the lab directory/DNS, clean rollback material, and a private baseline record.

7.4. Procedures

1. Create one Windows member VM and one Linux VM on the Endpoints bridge, with one NIC each. Use synthetic device names and clean lab profiles. Do not copy a real profile, corporate endpoint, browser session, or credential store.
2. Patch and establish named standard users plus separate administration. Join only the approved Windows VM to `ad.lab.test`; Linux directory join is optional and requires a separate design decision rather than assumed parity.
3. Apply the Windows pilot Group Policy and the scoped Linux baseline. Keep host firewalls enabled, disable unnecessary services, and allow inbound management only from the approved administrative path. These host restrictions also cover traffic that stays within the zone.
4. Set lab DNS/time and review network profiles, IPv6 behavior, shared folders/clipboard/media, guest integration, forwarding, and adapters for bypass paths. Export no raw system inventory publicly.
5. Add the minimal synthetic application/service in its separate service VM if included in Stage F approval. Protect it with application roles rather than assuming that a firewall allow authorizes all data.
6. Retain local logs, approved backups, and a private baseline record. Capture sanitized baseline differences and unresolved OS/driver constraints.

7.5. Proposed commands

On the approved Windows **member endpoint**, not the DC, read-only PowerShell:

```
Test-ComputerSecureChannel -Verbose
```

This Microsoft command checks the member's domain secure channel; do not use it as a DC health verdict. Review OS firewall/privilege state through supported tools for each installed version; do not prescribe unverified Linux distribution commands before choosing a distribution.

7.6. Expected outcome

Two isolated, supported, baseline-managed endpoints and a minimal protected synthetic service, with standard-user workflows and separate administrative identities.

7.7. Verification

T08/T09/T12: inspect resultant policy and local privileges, then independently sign in as a standard synthetic user and exercise one authorized and one unauthorized resource. Confirm one-NIC attachment and active host firewalls; use lab mocks for denied management access.

7.8. Troubleshooting

If domain verification fails, check the member's lab DNS/time and secure-channel context; do not treat a member-only command as a DC test. If access works from an unintended device/context, inspect effective GPO, local rights, firewall profile, adapters, and shared integration paths before expanding deployment.

7.9. Rollback

Revert the specific pilot policy or restore the clean endpoint baseline. Rebuilding a lab endpoint is allowed only if its destructive rollback was approved and evidence/data are preserved. Do not alter domain-wide policy to work around one endpoint failure.

7.10. Completion criteria

R06 and applicable R05/R08 checks pass with separate engineering and owner acceptance. A Linux endpoint without directory join is labeled accurately.

8. Stage G - Enterprise PKI and identity security

8.1. Objective

Establish lab certificate trust and prove how valid, untrusted, expired, and revoked certificates behave in the chosen application.

8.2. Prerequisites

Accepted Stage F, explicit Stage G approval, approved CA design and algorithms/lifetimes, root/issuing VM budgets, supported AD CS media/roles, secure private key/backup custody, reviewed certificate templates, transfer media, and internal CRL/AIA publication plan. Root and issuing CA must be separate from the DC.

8.3. Required tools

Use supported AD CS and certificate-management tools, the CA consoles, certutil on a lab verification endpoint, reviewed offline transfer media, internal publication services, and encrypted key/backup custody.

8.4. Procedures

1. Create the standalone offline root CA VM with **no virtual NIC**. Use supported Active Directory Certificate Services (AD CS) procedures to configure its identity, key protection, certificate lifetime, renewal schedule, and controlled backup process. Keep it powered off except for approved signing/renewal work.
2. Create the separate domain-joined issuing CA in the identity zone. Generate its request and transfer only the reviewed request/certificate/CRL artifacts through approved media; never move the root private key to the issuer.
3. Configure internal AIA/CDP locations and publish the required chain and CRLs with a renewal/calendar owner before issuing leaf certificates. Availability of those endpoints must not require Internet or production DNS.
4. Restrict CA administration and template enrollment to named lab roles. Prevent unrestricted subject/Subject Alternative Name (SAN) input, unnecessary authentication Extended Key Usages (EKUs), broad enrollment, and private-key export. Record the template review and the limits of separation of duties in a one-owner lab.
5. Distribute lab trust only to approved lab systems. Issue a short-lived synthetic TLS server certificate for the selected application, bind it, and verify hostname, chain, usage, validity, and private-key protection.
6. Revoke a dedicated test certificate, publish a new CRL, account for caches, and verify failure in a selected relying application configured to check revocation. Test a separate expired/untrusted certificate without changing the domain clock. Record clients that soft-fail or do not check revocation.
7. Create encrypted supported CA backups and document isolated restoration, key custody, CRL renewal deadlines, and compromise response. No private key, certificate export, or root trust is placed in home/production or Git.

8.5. Proposed commands

On an approved lab verification endpoint, with `$LabCertificatePath` pointing to the reviewed synthetic public certificate:

```
certutil -verify -urlfetch $LabCertificatePath
```

This Microsoft verification command can contact AIA/CDP URLs carried by the certificate. Inspect those URLs first and permit only lab destinations. It supplements, and cannot replace, an end-to-end

relying-application test.

8.6. Expected outcome

A two-tier isolated PKI with offline root, constrained issuance, internal trust/revocation services, lifecycle evidence, and recoverable private key custody.

8.7. Verification

T10/T11: inspect offline-root NIC absence and issuing-template permissions; independently test valid, untrusted/expired, and revoked certificates in the selected lab application. Record cache/soft-fail behavior and CRL validity, without manufacturing a pass from a certificate dump alone.

8.8. Troubleshooting

If a valid certificate fails, inspect hostname/usage, lab trust, chain, time, and reviewed internal AIA/CDP reachability. If a revoked certificate is accepted, inspect the selected application's revocation mode, CRL freshness and caches; report soft-fail/unsupported behavior and do not change domain time or claim universal enforcement.

8.9. Rollback

Remove only the pilot binding/trust from the approved lab systems and restore the previous service certificate. Revoke affected test certificates. CA deletion/rekey or private-key recovery needs explicit scope approval; never restore an old CA snapshot and assume revocation/database consistency.

8.10. Completion criteria

R07 passes with issuance and relying-application rejection evidence, backups, renewal owner, and explicit limitations. Universal revocation enforcement or production-grade HSM security is not claimed.

9. Stage H - Least privilege and Zero Trust policies

9.1. Objective

Translate each business role into specific resource permissions, then test both permitted and denied actions.

9.2. Prerequisites

Accepted Stage G, explicit Stage H approval, role/resource inventory, named policy owners, approved twelve-case matrix, lab-only test identities, host/application enforcement capability, and policy backups.

9.3. Required tools

Use the application's effective-permission tools, directory/group and host/firewall consoles, the twelve-case matrix, private policy backups, and a separate timing/audit observation.

9.4. Procedures

1. For the analyst, engineer, administrator, unauthorized user, and revoked user, list the exact resource, action, port, group, and available device/context conditions. Each permission needs a business reason.
2. Create at least twelve allow/deny cases covering each role and resource, same-zone paths, direct-IP/name paths, ordinary-user management denial, and revoked access. Include the administrative path and infrastructure exceptions.
3. Apply narrow group/resource authorization and service accounts, then matching network/host restrictions. Remove redundant broad permits only after confirming required dependencies and console recovery.
4. Check whether another group membership, inherited application right, cached session, direct route, overlay adapter, local administrator right, or service credential grants the same access. Removing one permit is ineffective if another path still allows it.
5. Revoke a dedicated synthetic user's access; measure from the approved policy change to observed resource denial, including existing sessions and new sessions. Define cache/session invalidation and the fifteen-minute target explicitly.
6. Document which decisions are identity-aware and which are static network rules. Record unavailable device posture or continuous reevaluation as gaps; do not equate segmentation with full Zero Trust.

9.5. Proposed commands

No reusable live access policy or command is supplied before the resource/application choice. Export reviewed synthetic policy summaries and use vendor-native effective-permission tools under Stage H approval. Keep actual user/tenant/address values private.

9.6. Expected outcome

A traceable identity/resource policy set with twelve cases, independent same-zone controls, and a measured access-revocation path.

9.7. Verification

T06/T12: execute each approved case in its named identity/device context, observe the application result and independent firewall/host/application audit event, and compare effective permissions. Record revocation timing and limitations of existing-session termination.

9.8. Troubleshooting

If denial differs from the matrix, inspect inherited/additive group/application rights, alternate routes, host policy, service credentials, and cached sessions. Measure new and existing sessions separately during revocation; do not change the expected case or re-enable broad access to obtain a pass.

9.9. Rollback

Restore the specific previous policy from private backup via the protected administrator path. Revert only approved test memberships; never re-enable broad domain/network permissions to recover access. Recheck isolation after any rollback.

9.10. Completion criteria

R08 passes all twelve declared cases and the revocation target, or a documented gap blocks acceptance. Separate owner UAT confirms business workflows remain usable.

10. Stage I - Lab-only Tailscale and Twingate pilots

10.1. Objective

Compare two remote-access approaches against the same single-resource business workflow in separate lab environments.

10.2. Prerequisites

Accepted Stage H, explicit Stage I approval for both sequential pilots, resolved isolated-egress decision, current vendor plan/terms review, independent lab-only identities/tenants, MFA and account recovery, connector/device budgets, and approved pilot resource/ports. No corporate SSO, tailnet, Twingate network, or production-connected client is permitted.

10.3. Required tools

Use separate lab-only vendor consoles, approved client/connector packages, MFA/recovery, the scoped resource matrix, private token handling, and local route/DNS/host-policy inspection. Provider tools are installed only within the future approved stage.

10.4. Procedures

1. Confirm that the external identity will not enroll into an existing corporate environment. Before connecting a device, verify separate lab administration, test-user groups, recovery, audit access, and the plan's actual device-posture/logging features.
2. Pilot Tailscale first. Replace its initial allow-all policy with reviewed explicit narrow grants/ACLs before enrolling devices. Verify the effective policy rather than assuming omitted or empty policy content denies access. Restrict tag owners and eliminate every additive wildcard path.
3. Expose one synthetic resource through a scoped dedicated lab component or explicitly approved directly enrolled lab endpoint. No subnet router, exit node, route advertisement, public sharing, or production DNS integration. For direct enrollment, treat overlay host policy as a separate boundary because it can bypass OPNsense.
4. Review outbound vendor connectivity and local DNS changes, authorize only necessary destinations/protocols, and test permitted, unauthorized, and revoked identities plus offline/recovery behavior. Record plan-specific limits rather than claiming unsupported device posture/MFA coverage.
5. Disable/disconnect the Tailscale pilot and restore approved DNS/routes before starting Twingate. Running both clients together could change which product handles traffic or DNS and make the comparison unreliable.
6. Create a separate Twingate lab network and connector in the remote zone using the currently supported vendor deployment method. Keep deployment tokens in the supported private secret mechanism. Define one exact Resource and explicit port restrictions; do not leave all-port/wildcard defaults.
7. Independently restrict connector-to-resource reachability in OPNsense/host policy, allowing only needed DNS and application dependencies. A connector compromise must not gain directory, management, or protected-network access. No inbound Internet listener/port forward is added.
8. Repeat the same role/deny/revocation cases, capture permitted vendor audit data privately, and compare identity/device requirements, policy precision, DNS behavior, logging, revocation timing, limitations, and recovery. Revoke unused pilot tokens/devices and close temporary egress permits.

10.5. Proposed commands

On the enrolled **lab Tailscale device** only, read-only status after policy review:

```
tailscale status
```

See Tailscale documentation and Twingate documentation. Status output can identify users/devices/addresses and is private. No token-bearing enrollment command, remote shell installer, or deployment credential is included in this guide. Verify current vendor endpoint/port requirements at execution time; do not open blanket Internet egress from all guests.

10.6. Expected outcome

Two comparable, isolated, resource-scoped remote-access pilot reports without a production connection, subnet exposure, or persistent broad policy.

10.7. Verification

T13/T14: independently inspect effective vendor policies and local routes/DNS, then test the same allowed/denied/revoked cases against the one lab resource. Inspect connector-zone enforcement and provider logs. Use lab mock protected targets for any attempted bypass case; never test actual home/production destinations.

10.8. Troubleshooting

If enrollment selects a corporate environment, stop before connecting and resolve the separate lab identity/tenant choice. If access or DNS differs from expectation, inspect the one active client, additive policy, exact resource/port, connector reachability, approved vendor egress, and caches; do not reset to allow-all or add subnet/exit-node routing.

10.9. Rollback

Disable the pilot resource, revoke pilot enrollments/tokens, stop the connector/client, restore approved lab DNS/routes, and remove temporary egress permits under the approved rollback. Confirm console administration still works. Do not delete a vendor account or existing environment unless expressly authorized.

10.10. Completion criteria

R09 and applicable R08/R10 tests pass for both pilots with measured limits; plan or egress blockers remain explicit if unresolved. Owner chooses whether either pilot should remain enabled in a future task.

11. Stage J - Security monitoring and audit logging

11.1. Objective

Collect the events needed to explain access decisions and detect when a source stops reporting.

11.2. Prerequisites

Accepted Stage I or an explicitly approved dependency exception, explicit Stage J approval, available storage/collector VM budget, lab PKI/DNS/time, six-source event inventory, retention/access policy, private evidence location, and approved synthetic event-generation scope.

11.3. Required tools

Use approved WEC/subscription management, supported syslog/journal tools, private source/collector records, the lab time authority, storage/quota measurements, and an approved benign event set.

11.4. Procedures

1. Confirm each component retains local logs. List the six required source classes: firewall, hypervisor, DC/DNS, Windows endpoint, Linux endpoint, and remote access. Record each provider's export/retention limits and any missing coverage.
2. Create the WEC and Linux/syslog collectors in the monitoring zone. Restrict administration and source submission. Configure source-initiated Windows event forwarding with an explicit source-computer ACL and authenticated transport; use TLS where designed. Do not broadly enable remote management.
3. Configure encrypted/authenticated syslog or supported secure collection for firewall, hypervisor, and Linux events. If a source lacks the selected transport, document an approved isolated-path exception and residual risk; do not claim encryption that is absent.
4. Select security-relevant events: synthetic authentication failures/success, privilege/group changes, administrative actions, DNS/policy changes, certificate events, allowed/denied flows, and remote-session decisions. Avoid passwords, tokens, message bodies, or customer data.
5. Normalize UTC timestamps and check each source against the chosen lab time authority. Set source-health/missing-log alerts and restrict log deletion/export. Keep raw logs private.
6. Generate twenty approved benign synthetic events across all six classes. Compare source and collector timestamps, measure how soon each event is searchable, and record missing/duplicate events. At least nineteen must be searchable within five minutes, with every class represented.
7. Measure daily ingestion/storage rate and calculate thirty-day retention plus margin within the capacity ledger. Configure rotation/quota and alert thresholds. A calculation proves design capacity only; demonstrate actual aging/rotation separately and label the observation period.

11.5. Proposed commands

On the approved Linux collector or source, local read-only journal inspection:

```
journalctl --since today --no-pager
```

Use the systemd journal reference matching the installed distribution. Output is private. WEC setup is performed using the reviewed Microsoft subscription guidance, not an unrestricted remote-management shortcut.

11.6. Expected outcome

Six-class collection with access controls, UTC correlation, measured ingestion, retention sizing, and a documented response to a missing source.

11.7. Verification

T15/T16: compare local source events with collector search results and record independent wall-clock/timing observations. Check denied log access and source interruption using only an approved lab source. Verify retention settings and capacity calculations separately from actual elapsed retention.

11.8. Troubleshooting

If an event is missing, compare the local source record with subscription/source ACLs, authenticated transport/certificate state, source time, collector health, and quota. If storage cannot support retention, record measured volume and revise approved capacity/rotation; do not clear logs, drop a source class silently, or claim elapsed retention from a calculation.

11.9. Rollback

Disable only the new subscriptions/forwarders, restore previous source policy, and retain local logging and captured evidence. Do not clear event logs to fix collection or reset a collector containing needed records.

11.10. Completion criteria

R10 meets the six-source, 19-of-20 latency, clock, and retention-design targets with explicit export/transport limitations. No claim of thirty days of observed retention is made before that interval exists.

12. Stage K - Functional, negative, and security validation

12.1. Objective

Check the approved workflows and restrictions against the frozen test plan before accepting the lab's engineering results.

12.2. Prerequisites

Accepted prior stages or recorded scope exceptions, explicit Stage K authorization identifying synthetic sources/targets and permitted tests, current backups, test windows/stop conditions, the frozen role/flow matrix, and no protected assets in target inventory.

12.3. Required tools

Use the frozen test/role/flow matrices, named lab-only clients and test identities, effective-policy/log/counter views, a private evidence record, and the approved stop/recovery plan. No general scanner is required.

12.4. Procedures

1. Review TEST-PLAN.md, requirement coverage, installed versions, target list, and expected results. Resolve tests that would touch protected systems by using configuration inspection and lab-owned mocks instead.
2. Exercise the required DNS, domain logon/Group Policy, endpoint, application-role, PKI, and remote-pilot workflows. Observe the requested action itself; a running service or green dashboard alone does not show that the workflow works.
3. Execute explicit deny cases for inter-zone, same-zone, ordinary-user management, wrong resource/port, untrusted certificate, and revoked identity. Use bounded connection checks; no broad scan, exploit, brute-force test, or malware is authorized by this guide.
4. Correlate each observed result with effective policy and independent logs/counters. Check alternative adapters/routes, IPv6, DNS bypass, cached sessions, and overlay enforcement using scoped lab cases.
5. Run approved certificate-revocation, policy-revocation, logging interruption, and scoped isolation/fail-closed checks without changing home networking or probing production. Stop immediately on unexpected reachability.
6. Record PASS, FAIL, or NOT TESTED with the reason, evidence IDs, defects/severity, remaining risk, retest scope, and second observation. Fixes need a bounded approved change. Keep the declared expected result rather than changing it to fit an observation.
7. Submit engineering results for review, then run separately documented owner UAT for business usability. Do not mark owner acceptance from engineering self-review.

12.5. Proposed commands

No general scanning or attack command is proposed. Version-verified bounded checks must be written into the approved test record with exact lab-only destination, rate, expected response, and stop condition before execution. The repository validator may be run locally but cannot verify operational controls.

12.6. Expected outcome

A traceable, evidence-backed evaluation with honest failures/gaps, independent observations, and separate owner UAT.

12.7. Verification

T01-T17/T20 as applicable: all critical tests pass, at least 95% of approved applicable noncritical cases pass, and no high-severity unresolved issue remains. Read results against the frozen matrix and inspect evidence/actual test coverage; skipped cases do not count as passed.

12.8. Troubleshooting

If a negative test times out, first prove the approved working control case and inspect the intended denial event; a stopped service is not evidence of authorization enforcement. Stop on unexpected protected reachability or uncertain targets, preserve the failure record privately, and obtain the bounded correction/retest scope.

12.9. Rollback

End the bounded tests, disable temporary test accounts/policies under approval, restore affected approved configurations, and verify isolation. Preserve original failure evidence. Any destructive recovery or policy expansion beyond approval requires a new owner decision.

12.10. Completion criteria

R14 has an engineering verdict and separate UAT state. Unexecuted tests and accepted exceptions are explicit; critical failures block final implementation acceptance.

13. Stage L - Automation, recovery, and final documentation

13.1. Objective

Demonstrate repeatable approved changes, recovery of the agreed service scope, and an accurate final evidence record.

13.2. Prerequisites

Accepted Stage K, explicit Stage L approval, two named automation operations/targets, reviewed credentials mechanism, off-compute encrypted backup storage, supported AD/CA recovery procedures, isolated restore network, approved recovery scope/RPO/RTO, and final-report template.

13.3. Required tools

Use the approved existing PowerShell/Python/Ansible environment, private target/secret handling, supported AD/CA backup tools, encrypted off-compute storage, an isolated restore network, a separate clock, and Git/documentation checks.

13.4. Procedures

1. Choose two small useful operations, such as a lab inventory summary and one reviewed baseline-policy deployment. Before writing code, define allowed targets, expected changes, credential handling, logs, failure behavior, and rollback. Production and secret publication remain excluded.
2. Implement using the smallest suitable PowerShell/Python/Ansible tool. Review installed module versions and dependencies before any approved installation. Add focused tests for boundary/target rejection and meaningful failure paths.
3. For configuration automation, inspect syntax/check results privately, execute on one approved lab target, compare actual desired state through a separate tool, and repeat. Record zero unintended changes on the second run; a no-op check alone is not proof of idempotence.
4. Configure encrypted off-compute backups with private key custody and verify backup freshness. Include supported directory system-state/CA artifacts for the chosen recovery scope, not just VM snapshots. State excluded assets and a retention/capacity plan.
5. Restore the approved representative identity/application scope into disconnected networks. Follow the dependency order, avoid duplicate live DC identities, and use supported AD/PKI restore guidance. Measure backup age against the recovery point objective (RPO) of 24 hours and full scoped recovery time against the recovery time objective (RTO) of four hours.
6. Validate restored DNS/authentication, certificate/revocation publication, authorization, logs, and data consistency. Restore encrypted backup/key access as part of the drill. Do not reconnect until isolation/policy checks pass.
7. Complete the requirements/test/evidence index, final limitations and risks, architecture-as-built differences, operating/recovery instructions, remote-pilot comparison, rubric assessment, and evidence-backed achievement statements. Leave owner UAT separate and explicit.
8. Run local repository checks, manually review every proposed public artifact and history, publish on the task branch, verify CI, and use a PR for review. Synchronize local `main` only after reviewed merge. Stop after the approved scope.

13.5. Proposed commands

For a **future, existing, reviewed** Ansible playbook, on the approved lab control node only:

```
ansible-playbook baseline.yml --syntax-check
ansible-playbook baseline.yml --check --diff --limit lab-pilot
```

`baseline.yml` and `lab-pilot` do not exist in Task 001. Ansible documentation explains that check mode is a simulation; modules can lack support and tasks can override it. Review the playbook before connecting. Diff output may expose secrets, so disable sensitive diffs and keep output private. Neither command authorizes a normal deployment.

Local repository checks, already permitted for Task 001 and later document changes:

```
python scripts/validate_docs.py
python -m unittest discover -s tests -v
git diff --check
```

13.6. Expected outcome

Two bounded repeatable automations, a timed isolated restore, an accurate final implementation report, sanitized evidence, and reviewed Git synchronization.

13.7. Verification

T18/T19/T20: independently inspect actual state after automation, measure recovery with a separate clock/service observation, validate backed-up data against the approved synthetic baseline, and review the final requirement/evidence index. Confirm UAT with the owner; no self-awarded acceptance.

13.8. Troubleshooting

If automation disagrees with the observed state, inspect target selection, module support, check-mode overrides, credentials, and private diffs before a normal rerun. If restore fails, inspect backup integrity/age, key access, scope, and dependency order in isolation; preserve the only valid backup and prevent duplicate live DC identities.

13.9. Rollback

Restore the specific configuration backup for an automation failure. Keep restored systems isolated and return to the last known approved lab baseline. Do not overwrite the only valid backup, bring duplicate DCs online, or destroy restore evidence. Cleanup/destructive rebuild needs explicit authorization.

13.10. Completion criteria

R12-R15 pass for the approved scope; actual measurements and residual limitations are recorded; public artifacts pass review/CI; owner UAT and final acceptance are explicit. A final implementation completion claim is prohibited until these conditions are met.

14. Task 001 stop

This document is a blueprint. After repository bootstrap and synchronization verification, stop for owner review. Do not begin Stage A, install Proxmox, create VMs, deploy AD/PKI, configure OPNsense, enroll remote access, or generate security-test traffic without the corresponding new authorization.